

UAT-11985

Google AitM phishing infrastructure in email and QR-code URLs

Threat intelligence dossier

A campaign-specific hunt for five source-published hostnames in Microsoft Defender XDR EmailUrlInfo. The package deliberately does not claim behavioral detection of the WebSocket relay or successful account compromise.

CLASSIFICATION	CONFIDENCE	PRIMARY PLATFORM
Hunting query	Medium	Microsoft Defender XDR

Operational value 7/10

Fast retrospective scoping for delivered email URLs and QR-code-extracted URLs. Durable value is limited because the logic is IOC-based and infrastructure can rotate.

Executive Assessment

Decision-grade summary for threat research, detection engineering, and SOC operations.

Source facts

Cisco Talos reported a mid-2026 spearphishing campaign targeting Taiwan-based research organizations. The actor reused legitimate event information, hid actor-controlled destinations behind benign-looking links, modified QR codes in event posters, and operated a Google-themed AitM kit using HTTP POST plus WebSocket state updates.

Vendor interpretation

Talos assesses that consistent language and localization artifacts indicate AI-assisted lure production and a Simplified-Chinese primary development environment. These judgments are not query conditions.

Analyst inference

The five published hostnames are suitable for retrospective, campaign-specific URL hunting. The hostnames alone cannot distinguish successful phishing from blocked delivery, safe analysis, or unrelated access.

Unconfirmed

No tenant impact, account takeover, MFA bypass, attribution, or successful QR-code scan is assumed.

Metric	Assessment
Operational value	7 / 10
Logic type	IOC-based / campaign-specific artifact
Feasibility	High for Defender for Office 365 tenants
Durability	Low to medium; infrastructure can rotate

Threat Mechanics

Evidence-bounded decomposition of the observed campaign.

Stage	Source-supported behavior	Observable candidate	Detection value
Delivery	Spearphishing emails use legitimate event themes and deceptive hyperlinks.	Email URL inventory and message identifier.	Direct retrospective scoping.
QR lure	Legitimate posters were modified with malicious QR codes.	EmailUrlInfo UrlLocation = QRCode when extraction is available.	Shows whether a malicious hostname was embedded in QR content.
Credential access	Spoofed Google login relays identifiers, passwords, and MFA state.	Requires decrypted web/proxy or dedicated phishing-kit signatures.	Not reliably available in generic SIEM schemas.
C2 / relay	HTTP POST exfiltration plus persistent WebSocket state updates.	Proxy fields for method, hostname, upgrade, connection duration, and bytes.	Potential behavioral logic after schema validation.

Detection hypothesis

Se un attaccante distribuisce URL UAT-11985 in email o QR code, la telemetria Defender for Office 365 dovrebbe mostrare uno dei cinque hostname pubblicati in UrlDomain. Il comportamento potrebbe essere distinto dall’attività legittima tramite conferma del messaggio, UrlLocation, destinatari, verdict e click history, senza trattare il solo match come compromissione.

ATT&CK;

T1566.002 Spearphishing Link is directly supported. No ATT&CK; mapping is assigned to the unimplemented AI-analysis-evasion research.

Telemetry & Evidence Model

Required telemetry

Microsoft Defender for Office 365 advanced hunting table EmailUrlInfo.

Field	Reliability	Use
Timestamp	Documented	Temporal context
NetworkMessageId	Documented	Message pivot
Url	Documented	Raw URL review
UrlDomain	Documented	Exact hostname match
UrlLocation	Documented	Subject, body, attachment, or QRCode context
UrlChainId / UrlChainPosition	Documented	Redirect-chain context
ReportId	Documented	Event context

Optional enrichment

EmailEvents and UrlClickEvents can add recipients, delivery action, click identity, Safe Links action, and redirection context, but are intentionally excluded from the primary query to keep the hunt direct and independently reviewable.

Unavailable from this query

HTTP body, submitted credentials, WebSocket frames, MFA challenge content, and proof of token theft.

Failure conditions

Defender for Office 365 not deployed; URL extraction unavailable; QR image not decoded; infrastructure rotated; shortened or nested redirect obscures the hostname; telemetry outside retention.

Primary Hunting Logic

Hunting query - Untested implementation sketch

```
let UAT11985Domains = dynamic([
"google.morelessty.com",
"jmlh.morelessty.com",
"google.centerhoti.com",
"google.natrlyi.com",
"accounts.natrlyi.com"
]);
EmailUrlInfo
| where UrlDomain in~ (UAT11985Domains)
| project Timestamp, NetworkMessageId, Url, UrlDomain,
UrlLocation, UrlChainId, UrlChainPosition, ReportId
| order by Timestamp desc
```

Condition evidence

Condition	Basis
EmailUrlInfo	Official Microsoft Defender XDR schema; populated by Defender for Office 365.
UrlDomain in~ list	Five exact hostnames from the source-maintained Talos IOC file.
No threshold/window	No source evidence supports an arbitrary count or correlation window.
Projected context	Only documented fields required for investigation.

Assumptions

UrlDomain contains normalized hostnames and the tenant has sufficient retention. Case-insensitive matching accommodates normalization without broadening beyond the five hostnames.

Meaning of a result

Association with source-published infrastructure. It is not proof of delivery success, user interaction, credential submission, account takeover, or attribution.

Cross-SIEM Assessment

Microsoft Defender XDR

Primary Platform. Direct, documented URL fields and a documented QRCode location indicator provide the strongest available evidence.

Splunk

No reliable implementation can currently be written for this platform. Index, sourcetype, raw email product, URL extraction, QR decoding, and field names are environment-dependent. Required sample: one raw email URL event containing the five expected concepts. Validation: identify index/sourcetype, confirm extraction, compare raw and normalized host, then write a single-signal direct search. No pseudocode is published.

Google SecOps / Chronicle

No reliable implementation can currently be written for this platform. UDM can represent URLs, but no parser or email-to-UDM mapping was verified for this environment. Required sample: parsed email or proxy event showing metadata.event_type, target.url or target.hostname, message/user context, and parser name. Validate with UDM Search before authoring YARA-L.

Behavioral network opportunity

A future proxy rule may correlate actor-controlled hostname, HTTP POST, and WebSocket upgrade. It is deferred because the report does not define a benign baseline, the current environment schema is unknown, and encrypted traffic may hide method or headers.

Validation & Tuning

Validation steps

#	Experiment	Success criterion
1	Run a schema-only query against EmailUrlInfo.	Rows exist and required fields are populated.
2	Send a benign lab message containing a controlled QR code.	UrlLocation records QRCode or the limitation is documented.
3	Execute the hunt over available retention.	Results expose raw URL and NetworkMessageId for review.
4	Pivot any hit to message and click telemetry.	Delivery/click context is recoverable without inferring compromise.

False positives

Security scanning, sandbox detonation, researcher access, forwarded historical messages, or stale IOC reuse. These are expected review categories, not automatic allowlists.

Tuning

Do not suppress a hostname globally before validating ownership and time range. Prefer analyst disposition based on message direction, recipient, URL location, delivery action, click activity, and known security-tool egress.

Acceptance

At least one controlled or historical event returns correct field semantics and raw evidence.

Rejection

Hostnames are absent from extracted URL data, field semantics differ, or all results are confirmed benign security processing with no investigative value.

Failure

Table unavailable, QR extraction absent, insufficient retention, or redirects prevent host visibility.

Operational Playbook & References

Triage sequence

#	Action
1	Preserve the message; identify sender, recipients, delivery action, and UrlLocation.
2	For QRCode, compare the original image and decoded destination.
3	Pivot NetworkMessageId to delivery and click telemetry.
4	Escalate only with delivery, click, suspicious authentication, or token evidence.

Primary research

Cisco Talos, "UAT-11985: AI-assisted event lures delivering real-time Google AitM phishing," 8 October 2026.
hxxps://blog[.]talosintelligence[.]com/uat-11985/

Indicators and schema

hxxps://github[.]com/Cisco-Talos/IOCs/blob/main/2026/10/uat-11985.txt
hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-emailurlinfo-table

Release controls

Control	Result
Classification / confidence	Hunting / Medium
Execution status	Untested implementation sketch
Defanging / customer data	Verified / none
Scope	One query; no speculative translations

Final caveat

This dossier supports retrospective hunting and validation. It is not production-ready and must not be used as proof of compromise.

END OF DOSSIER